

Relatório de Atividades	
Módulo 1:	Coleta de Informações
Atividade 1:	Atividade de Coleta de Informações
Nome:	Luiz Eduardo de Andrade

1. Introdução

Esta atividade faz parte do módulo de Coleta de Informações, para a qual utilizamos as atividades do site: <https://pentesterlab.com/badges/recon>

No contexto desta sala, nosso foco é:

- 1) Descobrir arquivos que possam nos ajudar a coletar maiores informações sobre a empresa.
- 2) Explorar vulnerabilidades na página web.
- 3) Utilizar o terminal do Kali Linux para ter acesso a
- 4)

A sala é composta por vinte e sete tarefas:

- 1) Recon00 - Para este desafio, seu objetivo é recuperar o robots.txt do site principal para hackycorp.com.
- 2) Recon01 - Para este desafio, seu objetivo é gerar um erro 404/"Não Encontrado" no site principal do hackycorp.com.
- 3) Recon02 - Para este desafio, seu objetivo é recuperar o security.txt do site principal para hackycorp.com.
- 4) Recon03 - Para este desafio, seu objetivo é encontrar um diretório com listagem de diretórios no site principal para hackycorp.com.
- 5) Recon04 - Para este desafio, seu objetivo é encontrar um diretório que seja comumente usado para gerenciar aplicativos.
- 6) Recon05 - Para este desafio, seu objetivo é encontrar um diretório que não seja diretamente acessível.
- 7) Recon06 - Para este desafio, seu objetivo é acessar o host virtual padrão ("vhost").
- 8) Recon07 - Para este desafio, seu objetivo é acessar o host virtual padrão ("vhost") via TLS.

- 9) Recon08 - Neste desafio, seu objetivo é acessar os nomes alternativos no certificado.
- 10) Recon09 - Para este desafio, seu objetivo é acessar os cabeçalhos das respostas.
- 11) Recon10 - Para este desafio, seu objetivo é usar reconhecimento visual. Você precisará encontrar o site com a chave em red.
- 12) Recon11 - Para este desafio, seu objetivo é atacar um host virtual.
- 13) Recon12 - Para este desafio, seu objetivo é acessar um aplicativo com balanceamento de carga hospedado no endereço balancer.hackycorp.com.
- 14) Recon13 -
- 15) Recon14 - Para este desafio, seu objetivo é realizar uma transferência de zona em z.hackycorp.com
- 16) Recon15 - Para este desafio, seu objetivo é realizar uma transferência de zona na zona interna chamada: "int" usando o servidor de nomes de z.hackycorp.com.
- 17) Recon16 - Para este desafio, seu objetivo é obter a versão do bind usada por z.hackycorp.com.
- 18) Recon17 - Para este desafio, seu objetivo é olhar o nome do desenvolvedor que enviou o código para a organização no repositório test1 no Github (primeiro você precisará encontrar a conta do Github para a Hackycorp).
- 19) Recon18 - Para este desafio, seu objetivo é consultar o repositório público dos desenvolvedores da organização.
- 20) Recon19 - Para este desafio, seu objetivo é olhar o repositório repo7 e encontrar um endereço de e-mail diferente do outro.
- 21) Recon20 - Para este desafio, seu objetivo é olhar o repositório repo3 e verificar diferentes ramificações.
- 22) Recon21 - Para este desafio, seu objetivo é olhar o repositório repo4 e verificar diferentes ramificações.
- 23) Recon22 - Neste desafio, seu objetivo é encontrar um arquivo que foi excluído no repo9.
- 24) Recon23 - Para este desafio, seu objetivo é olhar o repositório repo0a e encontrar informações confidenciais na mensagem de confirmação.
- 25) Recon24 - Para este desafio, seu objetivo é observar o servidor usado para carregar ativos (JavaScript, CSS) e encontrar um arquivo chamado key.txt.
- 26) Recon25 - Para este desafio, seu objetivo é olhar para o servidor usado para

carregar ativos (JavaScript, CSS) e encontrar um arquivo chamado key2.txt. No entanto, desta vez você precisará estar logado para acessá-lo.

O Amazon Web Services (AWS) Simple Storage Service (S3) permite que os proprietários de arquivos definam permissões em arquivos. Historicamente, as regras "Qualquer usuário" não eram bem explicadas e levavam muitas pessoas a pensar que apenas pessoas em suas contas da Amazon poderiam acessar um arquivo. No entanto, isso estava permitindo que qualquer conta da AWS acessasse o arquivo.

27) Recon26 - Para este desafio, seu objetivo é observar o servidor usado para carregar ativos (JavaScript, CSS) e encontrar uma chave codificada em um dos arquivos JavaScript.

2. Desenvolvimento

Recon00

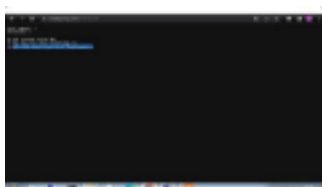
Configuração do ambiente: acessar o site <http://hackycorp.com>

Atividade prática: O objetivo deste laboratório é ter acesso ao arquivo robots.txt seguindo as seguintes etapas:

Execução do comando

Comando utilizado: `http://hackycorp.com/robots.txt`

Explicação do comando: Precisamos colocar o /robots.txt para acessar este arquivo, o robots.txt é utilizado para que os robôs acessem apenas as páginas autorizadas.

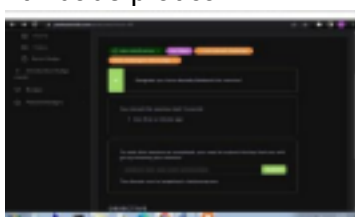


Por que isso foi feito? Para ter acesso ao arquivo de texto e saber quais páginas os robôs podem acessar

Análise dos Resultados: O site apresentou no browser o arquivo robots.txt e a chave do desafio

Interpretação dos resultados: foi necessário colocar uma barra e digitar robots.txt depois do site para que pudesse apresentar o texto

Atividade prática:



3. Considerações finais

As principais lições aprendidas incluem:

Não deixar o arquivo robots.txt exposto onde basta apenas saber o nome do arquivo e colocar uma barra para ter acesso a ele.

Recon01

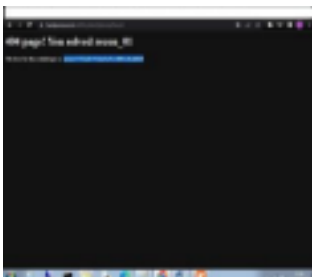
Configuração do ambiente: acessar o site <http://hackycorp.com>

Atividade prática: O objetivo deste laboratório é gerar uma página que não existe no site dando o erro 404 (não encontrado)

Execução do comando

Comando utilizado: `http://hackycorp.com/ddhfçalksdjfcñladsjçflaçld`

Explicação do comando: Precisamos colocar a /(barra) e uma página que não existe no site foi colocado uma sequência de caracteres.

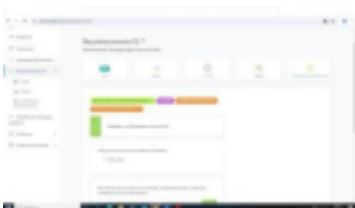


Por que isso foi feito? Para gerar uma página 404 que não existe no site Análise dos

Resultados: O site apresentou no browser a página 404 e a chave do desafio

Interpretação dos resultados: foi necessário colocar uma página que não existia no site hackycorp.com para que ele apresentasse a imagem acima.

Atividade prática:



3. Considerações finais

As principais lições aprendidas incluem: tomar cuidado com as páginas de erro pois podem vazarem informações e permitem que você detecte arquivos utilizando o diretório de força bruta.

Recon02

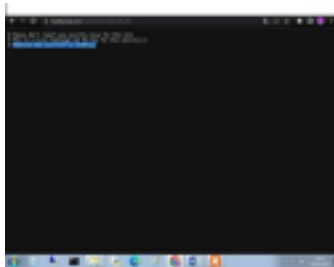
Configuração do ambiente: acessar o site <http://hackycorp.com>

Atividade prática: O objetivo deste laboratório é encontrar o arquivo `security.txt`

Execução do comando

Comando utilizado: `http://hackycorp.com/well-know/security.txt`

Explicação do comando: Precisamos colocar a `/`(barra) e diferente do primeiro desafio temos que colocar `well-know/security.txt`

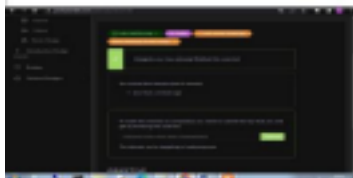


Por que isso foi feito? Para mostrar o arquivo `security.txt` ele serve para que profissionais de segurança relatem de forma fácil alguma vulnerabilidade no site.

Análise dos Resultados: O site apresentou o arquivo `security.txt` e a chave do desafio

Interpretação dos resultados: foi preciso colocar o comando `well-know` para que apresentasse o arquivo corretamente.

Atividade prática:



3. Considerações finais

Foi aprendido nesta lição que há um arquivo de texto que profissionais autônomos podem entrar em contato com os responsáveis pelo site para avisar sobre vulnerabilidades ou outra informação importante referente a segurança.

Recon03

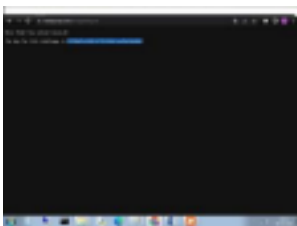
Configuração do ambiente: acessar o site <http://hackycorp.com>

Atividade prática: O objetivo deste laboratório é encontrar o arquivo

key.txt Execução do comando

Comando utilizado: <http://hackycorp.com/> clicar com o botão direito do mouse e selecionar view source page

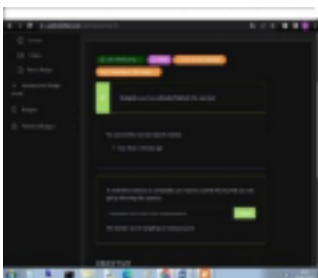
Explicação do comando: Precisamos localizar alguma imagem, css, Javascript para ter acesso aos diretórios dentro do site



Por que isso foi feito? Para mostrar a listagem do diretório dentro do site. Análise

dos Resultados: O site apresentou o arquivo security.txt e a chave do desafio

Interpretação dos resultados: Foi encontrado um link de uma figura images.logo, clicamos no link, na barra de endereço basta deletar o logo.png e o view-source no começo e no fim respectivamente que terá acesso ao diretório e ao arquivo key.txt.



3. Considerações finais

As principais lições aprendidas incluem: verificar os arquivos, css, Javascript, as imagens para que não abram diretórios diretamente no navegador, onde pode ser exposto senhas, credenciais, que podem causar uma invasão maior e potencialmente mais perigosa.

Recon04

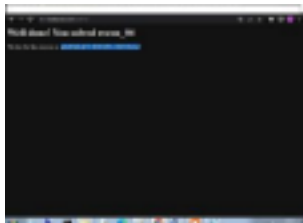
Configuração do ambiente: acessar o site <http://hackycorp.com>

Atividade prática: O objetivo deste laboratório é verificar se o /admin é aceito no site

Execução do comando

Comando utilizado: <http://hackycorp.com/admin>

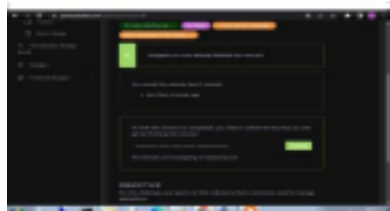
Explicação do comando: Podemos utilizar algumas palavras-chave como admin e verificar manualmente se o site as aceita.



Por que isso foi feito? Para verificar se o site estava vulnerável a palavras comuns como admin.

Análise dos Resultados: O site apresentou a chave do desafio

Interpretação dos resultados: Alguns sites têm esta falha que pode ser



explorada

3. Considerações finais

As principais lições aprendidas incluem: não deixar o site com palavras fáceis como admin para que o atacante não utilize isso para entrar como administrador no site.
Recon05

Configuração do ambiente: acessar o site <http://hackycorp.com> e terminal Kali Linux

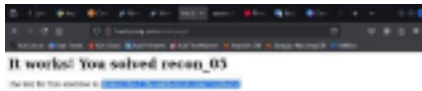
Atividade prática: O objetivo deste laboratório é usar força bruta de nomes comuns de diretório

Execução do comando

Comando utilizado: wfuzz -c -z file, wordlist/general/common.txt -sc 200

<http://hackycorp.com/FUZZ/> <http://hackycorp.com/start-page>

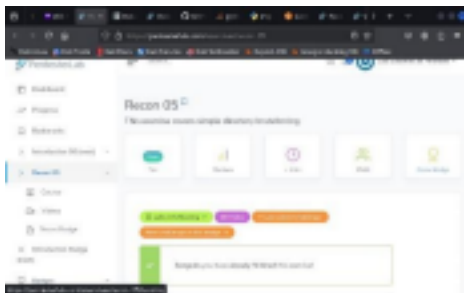
Explicação do comando o primeiro comando nos informou muitas palavras-chave, a palavra chave correta é start-page.



Por que isso foi feito? Para verificar se o site estava vulnerável a palavras comuns através de força bruta.

Análise dos Resultados: O site apresentou a chave do desafio

Interpretação dos resultados: Alguns sites têm esta falha que pode ser explorada por força bruta



3. Considerações finais

As principais lições aprendidas incluem não deixar palavras comuns na raiz do site que elas podem ser utilizadas através de ataque de força bruta.

Recon06

Configuração do ambiente: acessar o kali Linux através do terminal

Atividade prática: O objetivo deste laboratório é acessar o host virtual padrão (vhost) de uma forma diferente quando foi feito através da barra de endereço do site.

Execução do comando

Comandos utilizados no kali linux: dig hackycorp.com, vamos copiar o ip que aparece, depois colocamos o comando curl http://51.158.147.132/ -v, outra forma é colocar curl http://hackycorp.com/ -v -H "Host: test" ou inserir diretamente o ip na barra de endereço

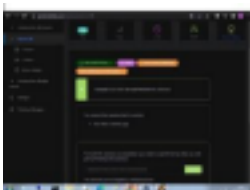
Explicação do comando: Utilizamos o dig para acessar o número de ip do site. Utilizamos o -v para mostrar saídas de formas mais explicadas.



Por que isso foi feito? Através do Kali Linux conseguimos atingir o

vhost Análise dos Resultados: O site apresentou a chave do desafio

Interpretação dos resultados: Podemos utilizar alguns comandos para descobrir o ip do site e consultar servidores de nomes DNS e obter informações sobre endereços de host, servidores de troca de e-mail e outros, informações valiosas sobre o alvo.



3. Considerações finais

As principais lições aprendidas incluem: verificar as páginas web para que não sejam invadidas ou corrompidas por agentes maliciosos.

Recon07

Configuração do ambiente: acessar o site <https://hackycorp.com>, utilizar o terminal do kali linux

Atividade prática: O objetivo deste laboratório é acessar o host virtual padrão (vhost) através do TLS.

Execução do comando

Comandos utilizados no kali linux: dig hackycorp.com, vamos copiar o ip que aparece, depois colocamos o comando curl https://51.158.147.132/ para acessar temos que digitar <https://51.158.147.132/> --insecure

Explicação do comando: Utilizamos o dig para acessar o número de ip do site, quando achamos o ip e digitamos com https não dará certo porque o certificado não corresponde ao IP, por fim utilizamos o comando https://51.158.147.132/ --insecure e

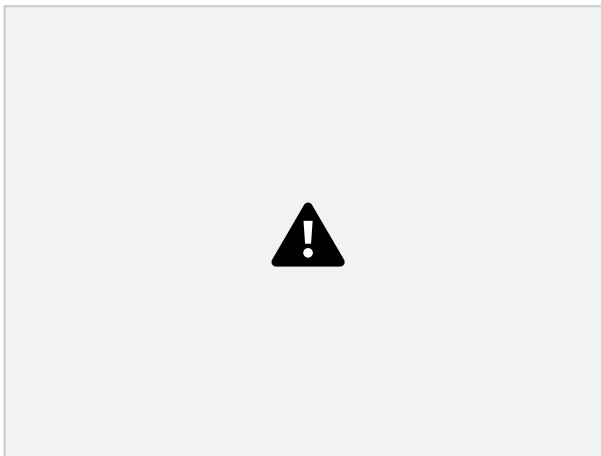
podemos utilizar o mesmo comando -v que indicará mais informações inclusive o handshake de TLS.



Por que isso foi feito? Para conseguir burlar o protocolo TLS

Análise dos Resultados: O site apresentou a chave do desafio e o handshake TLS.

Interpretação dos resultados: Podemos utilizar o dig para conseguir o número do IP, colocamos https mas não foi possível pois o certificado não era válido, então colocamos o comando <https://hackycorp.com/> --insecure para ter acesso.



3. Considerações finais

As principais lições aprendidas incluem: mesmo com HTTPS o site pode ser invadido através do protocolo TLS

Recon08

Configuração do ambiente: acessar o site <https://hackycorp.com/>, utilizar o terminal do kali linux

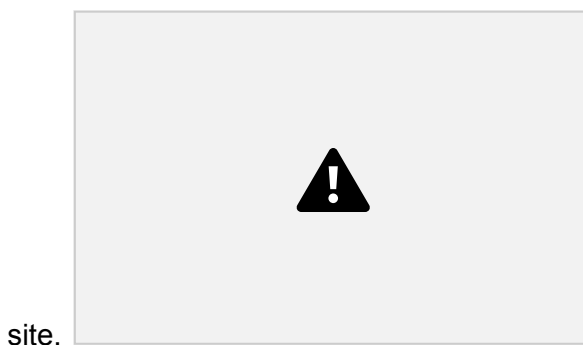
Atividade prática: O objetivo deste laboratório é acessar o DNS através do certificado digital.

Execução do comando

Comandos utilizados no navegador após acessar o site seguro cliquei no cadeado e depois em more information, temos informações sobre a validade e o dns, depois colocamos o dns no navegador mas apareceu a resolução do Recon06, foi verificado que não estava utilizando o https, quando o https foi incluído o site retornou com a

chave correta,no kali linux: curl
<https://66177e3f25e3ea0713807b1dc5f0b9df.hackycorp.com> e encontramos a mesma
chave

Explicação do comando: Utilizamos o curl para acessar o dns do



Por que isso foi feito? Para verificar se os servidores têm mais de um nome

Análise dos Resultados: O site apresentou a chave do desafio.

Interpretação dos resultados: Podemos utilizar o dns no navegador



3. Considerações finais

Podemos verificar que o atacante pode procurar por domínios diferentes para conseguir atacar a nossa infraestrutura.

Recon09

Configuração do ambiente: acessar o site <https://hackycorp.com>, utilizar o terminal do kali linux

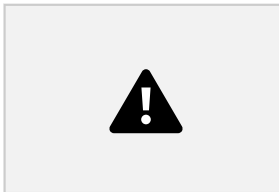
Atividade prática: O objetivo deste laboratório é acessar os cabeçalhos da

resposta Execução do comando

Comandos utilizados no Kali Linux: curl <https://hackycorp.com/> depois utilizaremos o

comando `https://hackycorp.com/ --dumper-header, https://hackycorp.com/ --dumper header -o /dev/null e https://hackycorp.com/ --dumper-header -o /dev/null -s`

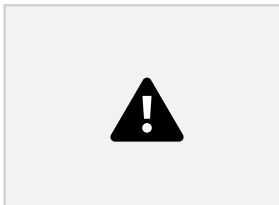
Explicação do comando: Utilizamos o curl `https://hackycorp.com/` teremos o HTML mas por padrão não irá aparecer o header, e depois utilizaremos o comando `https://hackycorp.com/ --dumper-header` mas ainda temos muito HTML, então então inserimos o comando `https://hackycorp.com/ --dumper-header -o /dev/null`, para restringir mais o HTML e direcionar para o repositório dev/null, para acharmos a resposta do desafio temos que utilizar o comando utilizamos `https://hackycorp.com/ -dumper-header -o /dev/null -s`



Por que isso foi feito? Para verificar se os headers dos cabeçalhos de respostas

Análise dos Resultados: O site apresentou a chave do desafio.

Interpretação dos resultados: Podemos utilizar o dump-header para verificar os cabeçalhos que podem conter informações valiosas.



3. Considerações finais

Pode utilizar os cabeçalhos para conseguir informações valiosas.

Recon10

Configuração do ambiente: no navegador colocamos uma `0x["%02x"].a.hackycorp.com` e o terminal do kali linux

Atividade prática: encontrar uma sequencia destes caracteres até achar a chave na cor vermelha

Execução do comando: `for i in `seq 0 150`; do Printf "0x%02x.a.hackycorp.com\n" $i`

Comandos utilizados no Kali Linux: `for i in `seq 0 150`; do`

```
Printf"0x%02x.a.hackycorp.com\n" $i >> hosts.txt
```

```
For i in cat `hosts.txt`; do curl $i/logo.png -o $i.png
```

Explicação do comando: para um primeiro comando fizemos um script para que ele tentasse todas as combinações possíveis

No segundo comando ele vai baixar todos os logos.png



Por que isso foi feito? Automatização do processo para que não tivesse que ser feito manualmente

Análise dos Resultados: baixamos todos os arquivos png

Interpretação dos resultados: basta encontrar o png com a chave



vermelha.

3. Considerações finais

A automatização é muito importante para que não tenhamos que fazer processos manualmente.

Recon11

Configuração do ambiente: terminal no kali linux utilizando docker, baixando o programa do git hub, utilizando o ffuz.

Atividade prática: atacar um host virtual através da ferramenta ffuz.

Comandos utilizados no Kali Linux: Execução do comando : 1º docker run -it golang, 2º go -u github.com/ffuf/ffuf, curl <https://hackycorp.com> -H 'Host:random123.hackycorp.com', 3º ffuf -w wfuzz/wordlist/general/common.txt -u <https://hackycorp.com> -H "Host: FUZZ.hackycorp.com" -fr recon07

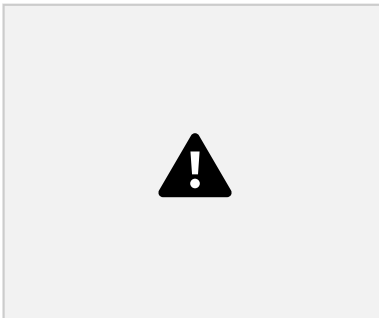
Explicação do comando: o primeiro comando serve para aplicarmos um docker golang dentro do kali linux, o segundo comando foi para descobrir qual era o target que teremos que atingir o recon07, o terceiro comando utilizamos para achar as correspondências



Por que isso foi feito? Utilizamos força bruta até achar o admin

Análise dos Resultados: o ffuz achou as palavras admin e www, funcionou com o admin.

Interpretação dos resultados: conseguimos mostrar a chave



3. Considerações finais

A ferramenta é importante para tentarmos ataque de força bruta, pois ela automatiza o trabalho.

Recon12

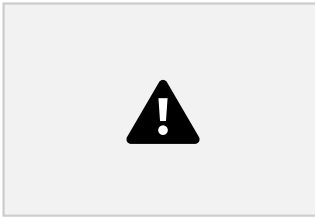
Configuração do ambiente: terminal no kali linux

Atividade prática: acessar um aplicativo com balanceamento de carga hospedado no endereço balancer.hackycorp.com.

Execução do comando

Comandos utilizados no Kali Linux: curl <http://balancer.hackycorp.com/>

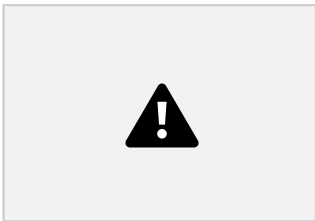
Explicação do comando: temos que executar o comando várias vezes



Por que isso foi feito? Para achar o load balancer

Análise dos Resultados: precisamos repetir o comando até achar a chave do desafio.

Interpretação dos resultados: foi possível achar o load balancer depois de algumas tentativas



3. Considerações finais

O load balancer ajuda a balancear as cargas entre os servidores, para que não haja a sub-utilização dos recursos.

Recon13

Configuração do ambiente: terminal Kali Linux

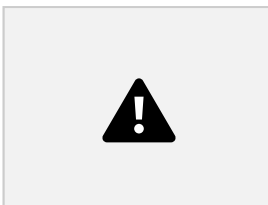
Atividade prática: encontrar o arquivo txt de key.z.hackycorp.com

Execução do comando

Comandos utilizados no Kali Linux: dig.key.z.hackycorp.com, dig -t TXT .key.z.hackycorp.com

Comandos utilizados no Kali Linux: dig.key.z.hackycorp.com, dig -t TXT .key.z.hackycorp.com

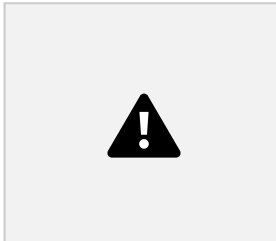
Explicação do comando: o primeiro comando nos retorna o tipo A ip e DNS, no segundo comando especificamos que queremos o arquivo texto



Por que isso foi feito? para ter acesso as configurações de serviços, nomes de pessoas

Análise dos Resultados: conseguimos encontrar a chave

Interpretação dos resultados: tivemos que colocar o txt no terminal para que pudesse nos direcionar diretamente a chave.



3. Considerações finais

Sempre verificar os arquivos TXT que podem ter informações para ajudar na coleta de informações.

Recon14

Configuração do ambiente: terminal linux

Atividade prática: transferência de zona em z.hackycorp.com

Execução do comando

Comandos utilizados no Kali Linux: dig AFXR z.hackycorp.com, dig -t SOA z.hackycorp.com, dig -t SOA z.hackycorp.com @z.hackycorp.com

Explicação do comando: o primeiro comando dará erro pois o DNS bloqueia para que não tenha muitas informações, o segundo comando utilizamos para pegar o NS do servidor e o último comando fez com que a conexão fosse direta.



Por que isso foi feito? para fazer uma conexão com o servidor diretamente sem passar pelo DNS

Análise dos Resultados: conseguimos a chave

Interpretação dos resultados: Tivemos que pegar o ns do servidor e aplicar depois

da nossa solicitação.



3. Considerações finais

Podemos nos comunicar diretamente com um servidor sem passar pelo DNS e conseguir diversas informações.

Recon15

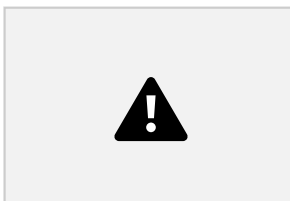
Configuração do ambiente: terminal Linux

Atividade prática: uma transferência de zona na zona interna chamada: "int" usando o servidor de nomes de z.hackycorp.com.

Execução do comando

Comandos utilizados no Kali Linux: dig -t NS z.hackycorp.com, dig AXFR int @z.hackycorp.com

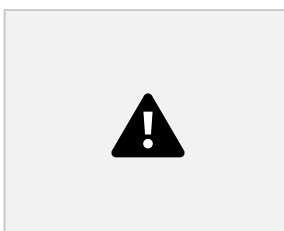
Explicação do comando: utilizamos o primeiro comando para conseguir o z.hackycorp.com, o outro comando foi para achar a chave



Por que isso foi feito? para

Análise dos Resultados: solicitar ao servidor externo informações sobre o servidor interno

Interpretação dos resultados: tivemos que pegar o ns e através do servidor externo conseguir a chave



3. Considerações finais

Podemos solicitar informações para o servidor para conseguir informações.

Recon16

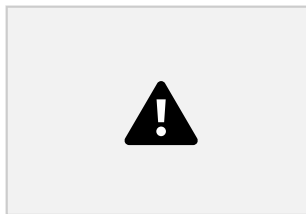
Configuração do ambiente: terminal Kali Linux

Atividade prática: obter a versão do bind usada por

z.hackycorp.com. Execução do comando

Comandos utilizados no Kali Linux: chaos txt VERSION.BIND

@z.hackycorp.com Explicação do comando: precisamos informar que

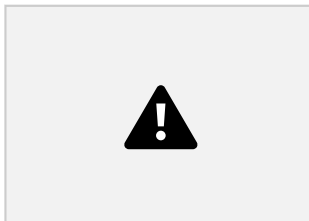


queremos a versao bind

Por que isso foi feito? para localizar a versão bind dentro do

@z.hackycorp.com Análise dos Resultados: encontrar a chave

Interpretação dos resultados: conseguimos acessar a chave através do



bind

3. Considerações finais

Podemos utilizar o bind que é um dos DNS mais utilizados para conseguir informações.
Recon17

Configuração do ambiente: internet, utilizar o git hub

Atividade prática: nome do desenvolvedor que enviou o código para a organização no repositório test1 no Github.

Execução do comando

Comandos utilizados no Kali Linux: procurar no google hacky corp no git hub

Explicação do comando: precisamos acessar o git hub para conseguir acessar a

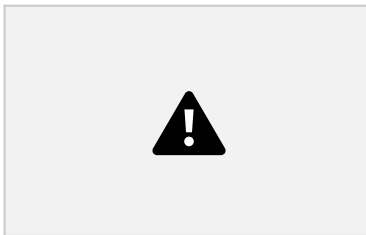


chave.

Por que isso foi feito? para encontrar o repositório test1

Análise dos Resultados: conseguimos encontrar a chave

Interpretação dos resultados: está dentro do repositório test1



3. Considerações finais

Utilizar o git hub para conseguir informações sobre softwares ou pessoas.

Recon18

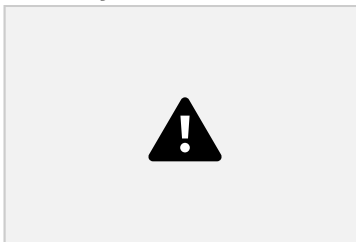
Configuração do ambiente: internet, utilizar o git hub

Atividade prática: consultar o repositório público dos desenvolvedores.

Execução do comando

Comandos utilizados no Kali Linux: ir no git hub clicar em people, depois em hackercorpdev, clicar em repositório, test1, clique em test

Explicação do comando



Por que isso foi feito? para conseguir a chave dentro do repositório

Análise dos Resultados:

Interpretação dos resultados: conseguimos a chave dentro do test e clicar no

documento test



3. Considerações finais

Conseguir acessar os repostórios do git hub.

Recon19

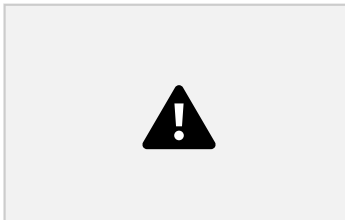
Configuração do ambiente: internet, git hub, kali linux

Atividade prática: seu objetivo é olhar o repositório repo7 e encontrar um endereço de e-mail diferente do outro.

Execução do comando

Comandos utilizados no Kali Linux: git clone <https://github.com/hackycorp/repo7>, cd repo7 ls git.log

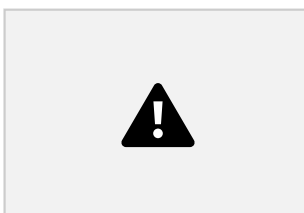
Explicação do comando: clonar o git hub, abrir o repo7 e o git log



Por que isso foi feito? precisamos clonar o git hub para

Análise dos Resultados: mostrar a chave

Interpretação dos resultados: Depois de clonar o git hub temos que utilizar o comando git.log para conseguir a chave



3. Considerações finais

Conseguir acessar os repositórios do git hub e os logs podem vazam algumas informações sobre contas pessoais ou sistemas internos.

Recon20

Configuração do ambiente: internet,

Atividade prática: seu objetivo é olhar o repositório repo3 e verificar diferentes ramificações.

Execução do comando

Comandos utilizados : <https://github.com/hackycorp/repo3>

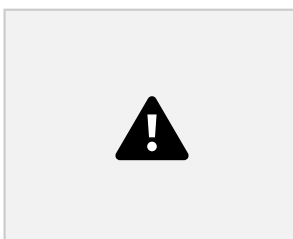
Explicação do comando: acessar o site e mudar a branch



Por que isso foi feito? para conseguir acesso a chave.

Análise dos Resultados: conseguir a chave

Interpretação dos resultados: mudar a branch onde está a chave.



3. Considerações finais

Verificar as diferentes branches para analisar as informações.

Recon21

Configuração do ambiente: internet

Atividade prática: seu objetivo é olhar o repositório repo4 e verificar diferentes ramificações

Execução do comando

Comandos utilizados : <https://github.com/hackycorp/repo4>

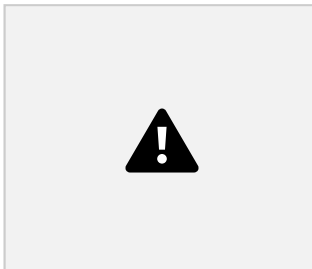
Explicação do comando: acessar o git hub onde está a chave



Por que isso foi feito? para acessar o git hub

Análise dos Resultados: achar a chave

Interpretação dos resultados: clicar em view all branches clique em test no stale branches, clique em key e achará a chave.



3. Considerações finais

Observar todas as filiais em busca de informações.

Recon22

Configuração do ambiente: internet e utilizar o terminal Kali Linux

Atividade prática: é encontrar um arquivo que foi excluído no

repo9. Execução do comando

Comandos utilizados : <https://github.com/hackycorp/repo9> e verificar os arquivos mais antigos, git clone : <https://github.com/hackycorp/repo9>, cd repo9, ls tig

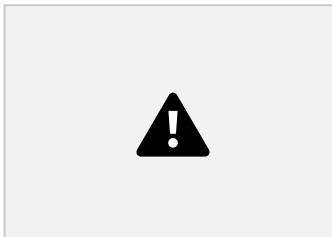
Explicação do comando: no git hub tem muitos arquivos, então vamos clonar o git hub e abrir o repositório e digitar tig para vermos o que foi alterado, podemos ver que o arquivo foi excluído



Por que isso foi feito? para ter acesso aos arquivos

Análise dos Resultados: conseguir o arquivo com a chave

Interpretação dos resultados: temos que procurar nos arquivos com o comando `tig` e vemos que a chave está neste arquivo.



3. Considerações finais

Verificar os arquivos excluídos atrás de informações.

Recon23

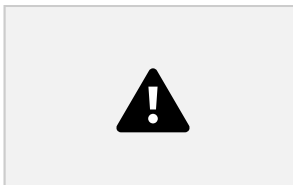
Configuração do ambiente:

Atividade prática: seu objetivo é olhar o repositório `repo0a` e encontrar informações confidenciais na mensagem de confirmação.

Execução do comando

Comandos utilizados no Kali Linux : <https://github.com/hackycorp/repo0a>, `git clone https://github.com/hackycorp/repo0a` `cd repo0a`, `tig`

Explicação do comando: entrar no git hub depois no kali linux fazer o clone



Por que isso foi feito? para ter acesso a chave

Análise dos Resultados: conseguir a chave

Interpretação dos resultados: procurar o arquivo nas mensagens de confirmação



3. Considerações finais

Procurar nos arquivos as mensagens de confirmação para colher os dados importantes.

Recon24

Configuração do ambiente: internet e terminal Kali Linux

Atividade prática: seu objetivo é observar o servidor usado para carregar ativos (JavaScript, CSS) e encontrar um arquivo chamado key.txt.

Execução do comando

Comandos utilizados : acessar o site <https://hackycorp.com>, no terminal Kali Linux dig assets.hackycorp.com,vimos que é o cloud front, substituir tudo depois da barra e digitar key.txt

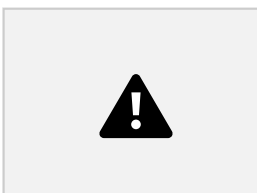
Explicação do comando: clicar com o botão esquerdo e view source page e acessar a página que tem o bootstrap, no terminal Kali Linux execute o comando dig assets.hackycorp.com, volte até o navegador , substituir tudo depois da barra e digitar key.txt



Por que isso foi feito? acessar a chave através do browser

Análise dos Resultados: encontrar a chave

Interpretação dos resultados: conseguimos chegar a chave tirando tudo depois da barra e colocando key.txt



3. Considerações finais

Procurar por arquivos que possam estar disponíveis publicamente.

Recon25

Configuração do ambiente: site <https://hackycorp.com>, terminal do Linux e conta AWS.

Atividade prática: Para este desafio, seu objetivo é olhar para o servidor usado para carregar ativos (JavaScript, CSS) e encontrar um arquivo chamado key2.txt. No entanto, desta vez você precisará estar logado para acessá-lo.

Execução do comando

Comandos utilizados : <https://hackycorp.com/key2.txt>, instalar o aws cli, `cd ~/.aws`, `cat config`, `cat credentials`, `aws s3 cp s3://assets.hackycorp.com/key2.txt`, `cat key2.txt`

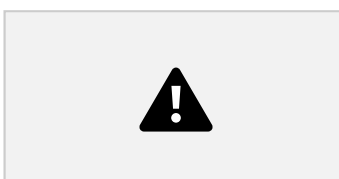
Explicação do comando quando colocar o site <https://hackycorp.com/key2.txt> irá informar que não tem acesso, depois da instalação temos que configurar a Key ID e Access Key para termos acesso ao s3, abrimos a pasta, fazemos a configuração e copiamos o arquivo do s3 para a nossa máquina, depois lemos o arquivo com o cat.



Por que isso foi feito? para acessar a chave no S3 da AWS

Análise dos Resultados: encontrar a chave

Interpretação dos resultados: conseguimos a chave depois que criamos uma conta na AWS e este bucket estava público.



3. Considerações finais

Temos que ter cuidado para não deixar buckets públicos com informações sensíveis.

Recon26

Configuração do ambiente: internet

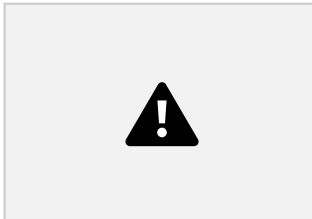
Atividade prática: seu objetivo é observar o servidor usado para carregar ativos

(JavaScript, CSS) e encontrar uma chave codificada em um dos arquivos JavaScript

Execução do comando

Comandos utilizados : acessar o site <https://hackycorp.com>

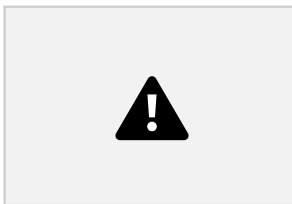
Explicação do comando: clicar com o botão esquerdo e view source page e acessar a página, procurar um segredo no código javascript, podemos procurar por script, abrir os 3 scripts no final do vendor e abrir um do custom, depois nestas 4 abas irá procurar por key,



Por que isso foi feito? acessar a chave através do javascript.

Análise dos Resultados: conseguir a chave

Interpretação dos resultados: procurar no javascript a chave



3. Considerações finais

Podemos encontrar no javascript algumas informações ou APIs importantes para o ataque.

4. Referências

- 1) <https://pentesterlab.com/exercises/recon-00/videos> 2)
- <https://en.wikipedia.org/wiki/Robots.txt> 3)
- <https://pentesterlab.com/exercises/recon-01/videos> 4)
- <https://pentesterlab.com/exercises/recon-02/videos> 5)
- <https://securitytxt.org/>
- 6) <https://en.wikipedia.org/wiki/Security.txt> 7)
- <https://pentesterlab.com/exercises/recon-03/videos> 8)
- <https://pentesterlab.com/exercises/recon-04/videos> 9)
- <https://pentesterlab.com/exercises/recon-05/videos> 10)
- <https://pentesterlab.com/exercises/recon-06/videos> 11)
- <https://pentesterlab.com/exercises/recon-07/videos> 12)
- <https://pentesterlab.com/exercises/recon-08/videos> 13)
- <https://pentesterlab.com/exercises/recon-09/videos> 14)
- <https://pentesterlab.com/exercises/recon-10/videos> 15)

<https://pentesterlab.com/exercises/recon-11/videos> 16)
<https://pentesterlab.com/exercises/recon-12/videos> 17)
<https://pentesterlab.com/exercises/recon-13/videos> 18)
<https://pentesterlab.com/exercises/recon-14/videos> 19)
<https://pentesterlab.com/exercises/recon-15/videos> 20)
<https://pentesterlab.com/exercises/recon-16/videos> 21)
<https://pentesterlab.com/exercises/recon-17/videos> 22)
<https://pentesterlab.com/exercises/recon-18/videos> 23)
<https://pentesterlab.com/exercises/recon-19/videos> 24)
<https://pentesterlab.com/exercises/recon-20/videos> 25)
<https://pentesterlab.com/exercises/recon-21/videos> 26)
<https://pentesterlab.com/exercises/recon-22/videos> 27)
<https://pentesterlab.com/exercises/recon-23/videos> 28)
<https://pentesterlab.com/exercises/recon-24/videos> 29)
<https://pentesterlab.com/exercises/recon-25/videos> 30)
<https://pentesterlab.com/exercises/recon-26/videos>

31) <https://www.youtube.com/watch?v=x7lv84xvdhs>